

INFORME MAGERIT, INDICADORES DE CIBERSEGURIDAD E INTEGRACIÓN CON NIS2 EN ESPAÑA

Tendencias, Regulación y Operacionalización 2024-2026

RESUMEN EJECUTIVO

Este informe analiza la evolución de **MAGERIT (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información)** en el contexto regulatorio español 2024-2026, con énfasis en su integración con la **Directiva NIS2**, la actualización del **Esquema Nacional de Seguridad (ENS, RD 311/2022)** y el desarrollo de **indicadores cuantitativos de ciberseguridad** alineados con mejores prácticas internacionales.

Hallazgos clave:

- MAGERIT v3 permanece como la metodología de referencia nacional para análisis de riesgos en sistemas de información, implementada mediante el Método de Análisis de Riesgos (MAR) estructurado en cuatro tareas: activos, amenazas, salvaguardas y estado de riesgo residual.¹²
- El ENS (actualizado por RD 311/2022) operacionaliza MAGERIT mediante 22 requisitos mínimos y medidas de seguridad proporcionadas (marcos organizativo, operacional y de protección) clasificadas por categoría de sistema (BÁSICA/MEDIA/ALTA) y madurez (L2-L4 CMM).³
- España gestiona indicadores de ciberseguridad fragmentados: 97.348 incidentes en 2024 (+16,6% vs 2023), con madurez promedio nacional de 61% en dominios NIST (Identify 68%, Respond 55%, Recovery 53%). Sectores financiero (72%) y construcción (68%) lideran; Distribución y Bienes de Consumo (51-52%) rezagados.⁴⁵
- La integración MAGERIT + NIS2 requiere operacionalización mediante análisis cuantitativos de riesgo (FAIR/ALE) complementarios a MAGERIT, con énfasis en cuantificación financiera de impacto y alineación con autoridades supervisoras centralizadas (Centro Nacional de Ciberseguridad, aún en creación enero 2025).⁶³

1. CONTEXTO REGULATORIO: NIS2 Y TRASPOSICIÓN ESPAÑOLA

1.1 Situación Normativa (Enero 2025)

La **Directiva NIS2** (UE 2022/2555) entró en vigor en enero de 2023, con plazo de trasposición a 17 de octubre de 2024 incumplido por España. El **Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad** (enero 2025) establece el marco nacional, pendiente de aprobación oficial.¹

Aspecto	Estado
Ley de Trasposición	Anteproyecto (ene 2025), aprobación esperada 2025-2026
Autoridad Competente Nacional	Centro Nacional de Ciberseguridad (creación en proceso)
Autoridades de Control	CCN (defensa), SETELECO/SEDIA (digital), OCI (interior), por sector
Certificación Entidades Esenciales	Obligatoria (auditoría externa bienal)
Autoevaluación Entidades Importantes	Permitida (sin auditoría periódica obligatoria)
Sanciones Esenciales	€10M o 2% volumen negocios (máxima cuantía)
Sanciones Importantes	€7M o 1,4% volumen negocios

Nota crítica: Las empresas españolas operan bajo vinculatoriedad de NIS2 desde enero 2023, sin marco legislativo nacional claro. El Anteproyecto recomienda usar **ENS + Reglamento de Ejecución UE** como referencias transitorias.²

² <https://assets.kpmg.com/content/dam/kpmgsites/es/pdf/2024/12/claves-cumplir-directiva-nis2.pdf>.coredownload.inline.pdf

² <https://assets.kpmg.com/content/dam/kpmgsites/es/pdf/2024/12/claves-cumplir-directiva-nis2.pdf>.coredownload.inline.pdf

² <https://www.ccn-cert.cni.es/es/documentos-publicos/1789-magerit-libro-i-metodo/file?format=html>

² [https://es.wikipedia.org/wiki/Magerit_\(metodolog%C3%ADa\)](https://es.wikipedia.org/wiki/Magerit_(metodolog%C3%ADa))

² <https://zaguan.unizar.es/record/145837/files/TAZ-TFM-2024-1152.pdf>

² <https://dspace.ups.edu.ec/bitstream/123456789/26674/1/UPS-CT011073.pdf>

² <https://www.gub.uy/agencia-gobierno-electronico-sociedad-informacion-conocimiento/book/6611/download>

² <https://elperiodicodelaenergia.com/los-ataques-a-infraestructuras-espanolas-aumentaron-un-43-en-2024-y-se-mantienen-en-2025/>

² https://ptedisruptive.es/wp-content/uploads/2024/12/INFORME-DE-SITUACION_CIBERSEGURIDAD_2024.pdf

² <https://www.incibe.es/incibe/sala-de-prensa/incibe-presenta-su-balance-de-ciberseguridad-2024-con-mas-de-97000-incidentes>

² <https://www.tendencias.kpmg.es/2024/03/apostar-cuantificacion-riesgos-ciberseguridad-2/>

² <https://dspace.ups.edu.ec/bitstream/123456789/26674/1/UPS-CT011073.pdf>

² <https://www.gub.uy/agencia-gobierno-electronico-sociedad-informacion-conocimiento/book/6611/download>

² <https://zaguan.unizar.es/record/145837/files/TAZ-TFM-2024-1152.pdf>

² [https://es.wikipedia.org/wiki/Magerit_\(metodolog%C3%ADa\)](https://es.wikipedia.org/wiki/Magerit_(metodolog%C3%ADa))

² <https://www.ccn-cert.cni.es/es/documentos-publicos/1789-magerit-libro-i-metodo/file?format=html>

² <https://assets.kpmg.com/content/dam/kpmgsites/es/pdf/2024/12/claves-cumplir-directiva-nis2.pdf>.coredownload.inline.pdf

² <https://zaguan.unizar.es/record/145837/files/TAZ-TFM-2024-1152.pdf>

² <https://elperiodicodelaenergia.com/los-ataques-a-infraestructuras-espanolas-aumentaron-un-43-en-2024-y-se-mantienen-en-2025/>

² <https://dspace.ups.edu.ec/bitstream/123456789/26674/1/UPS-CT011073.pdf>

² <https://www.gub.uy/agencia-gobierno-electronico-sociedad-informacion-conocimiento/book/6611/download>

1.2 Criterios de Clasificación NIS2

Categoría	Criterios	Supervisión
Esenciales	>250 empl. + balance >€43M O volumen negocios >€50M + sector Anexo I	Auditoría obligatoria periódica + ad-hoc
Importantes	Sector Anexo II O no cumplen criterios esencial pero sí sector aplicable	Supervisión a posteriori (si indicios)
Sectores Anexo I (críticos)	Energía, Transporte, Banca, Finanzas, Salud, Agua, TIC, Admin. Pública, Espacio	

-
- 2 <https://www.boe.es/buscar/act.php?id=BOE-A-2022-7191>
- 2 https://ptedisruptive.es/wp-content/uploads/2024/12/INFORME-DE-SITUACION_CIBERSEGURIDAD_2024.pdf
- 2 <https://www.administracionpublicadigital.es/tecnologias/2025/03/el-balance-de-2024-de-incibe-deja-un-incremento-del-166-respecto-a-2023>
- 2 <https://master.ismsforum.es/wp-content/uploads/2024/09/indicador-de-madurez-en-ciberseguridad-2020-1.pdf>
- 2 <https://www.incibe.es/incibe/sala-de-prensa/incibe-presenta-su-balance-de-ciberseguridad-2024-con-mas-de-97000-incidentes>
- 2 <https://www.youtube.com/watch?v=8nMfIR57tLg>
- 2 <https://secureframe.com/es-es/blog/cyber-risk-quantification>
- 2 <https://www.tendencias.kpmg.es/2024/03/apostar-cuantificacion-riesgos-ciberseguridad-2/>
- 2 <https://www.emerald.com/insight/content/doi/10.1108/ics-03-2023-0043/full/html?skipTracking=true>
- 2 <https://pubmed.ncbi.nlm.nih.gov/23867032/>
- 2 <https://www.escuelaeuropeaexcelencia.com/2024/11/3-indicadores-en-iso-27001-que-son-clave-para-garantizar-la-seguridad-de-la-informacion/>
- 2 https://eprints.soton.ac.uk/411068/1/Using_Goal_Question_Metric_GQM_Approach_to_Assess_Security_in_Cloud_Storage.pdf
- 2 <https://pmc.ncbi.nlm.nih.gov/articles/PMC7877299/>
- 2 <https://compleye.io/es/articulos/iso-27001-frente-al-marco-de-ciberseguridad-del-nist-cual-es-la-diferencia/>
- 2 <https://panaseer.com/resources/blog/goal-question-metric>
- 2 <https://pmc.ncbi.nlm.nih.gov/articles/PMC4540688/>
- 2 <https://www.onetrust.com/es/blog/iso-27001-vs-nist-cybersecurity-framework/>
- 2 <https://dialnet.unirioja.es/descarga/articulo/10370798.pdf>
- 2 <https://www.sciencedirect.com/science/article/abs/pii/S0749379713002651>
- 2 <https://ticnova.es/blog/marcos-referencia-gestion-riesgo/>
- 2 http://sedici.unlp.edu.ar/bitstream/handle/10915/114192/Documento_completo.pdf-PDFA.pdf?sequence=1&isAllowed=y
- 2 <https://pmc.ncbi.nlm.nih.gov/articles/PMC9677469/>
- 2 <https://secureframe.com/es-es/hub/iso-27001-vs-nist>
- 2 <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-39.pdf>
- 2 <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-55v1.pdf>

Sectores Anexo II	Postal, Gestión residuos, Industria química/nuclear, Alimentación, Telecomunicaciones, Manufactura	
--------------------------	--	--

2. MAGERIT V3: EVOLUCIÓN METODOLÓGICA Y OPERACIONALIZACIÓN

2.1 Arquitectura del Método de Análisis de Riesgos (MAR)

MAGERIT v3 (2012, actualizado con ENS 2022) estructura el análisis de riesgos en **cuatro tareas formalizadas (MAR.1-MAR.4)** dentro de un **ciclo PDCA** de gestión integral:34

Tarea MAR.1: Caracterización de Activos

- Identificación: Información, servicios, hardware, software, personal, instalaciones
- Valoración: Cálculo de impacto por dimensión (Confidencialidad, Integridad, Disponibilidad, Autenticidad, Trazabilidad)
- Dependencias: Modelado de cascadas de valor (acumulado/repercutido)
- Salida: Modelo de Valor (catálogo de activos críticos ponderado)

Tarea MAR.2: Caracterización de Amenazas

- Tipificación: Naturales, humanas accidentales/deliberadas, fallos técnicos
- Valoración: Degradación (% pérdida valor) × Frecuencia/Probabilidad anual (ARO)
- Salida: Mapa de Riesgos (matriz amenaza-activo-dimensión)

Tarea MAR.3: Caracterización de Salvaguardas

- Identificación: Preventivas (PR), Disuasorias (D), Detectivas (DE), Correctivas (C)
- Evaluación de eficacia: Madurez (L0-L5 CMM), cobertura de dimensiones
- Salida: Declaración de Aplicabilidad, Evaluación de Salvaguardas, Informe de Insuficiencias

Tarea MAR.4: Estimación de Estado de Riesgo

- Impacto residual: $\text{Valor activo} \times (\text{Degradación} \times (1 - \text{Eficacia salvaguardas}))$
- Riesgo residual: $\text{Impacto residual} \times \text{Frecuencia}$
- Análisis acumulado/repercutido según dependencias
- Salida: Estado de Riesgo, decisiones de tratamiento (eliminación, mitigación, compartición, aceptación/financiación)

Diferenciación clave vs NIST/FAIR:

- MAGERIT: Énfasis en impacto sobre activos (bottom-up), proporcionalidad (perfiles adaptables), formatos de salida estandarizados (declaraciones, informes).
- NIST CSF: Orientación a funciones empresariales (Identify→Protect→Detect→Respond→Recover), niveles madurez organizacional (L1-L4 por práctica).
- FAIR: Cuantificación monetaria pura ($\text{ALE} = \text{LEF} \times \text{LM}$, simulaciones Montecarlo), decisiones financieras ROI-céntricas.

→ **Integración recomendada:** MAGERIT (identificación/priorización) + FAIR (cuantificación ROI) + NIST CSF (validación funcional).⁵⁶⁷

2.2 Indicadores y Métricas en MAGERIT

MAGERIT NO define "indicadores de ciberseguridad" como módulo explícito, sino **métricas de estado de riesgo y control de procesos**:

Métrica	Fuente MAGERIT	Operacionalización
Cobertura de activos críticos	MAR.1 (completitud modelo valor)	% de activos identificados vs. inventario IT
Frecuencia/ARO (riesgos)	MAR.2 (probabilidad amenazas)	Incidentes históricos/año (INCIBE CERT, CCN-CERT)
Degradación media	MAR.2 (% pérdida valor/amenaza)	Impacto normalizado (0-100%)
Eficacia salvaguardas (%)	MAR.3 (L0-L5 madurez)	Reducción riesgo post-implementación (NIST/ISO validación)
Riesgo residual total	MAR.4 (agregado ponderado)	Suma ponderada impactos residuales (en euros vía FAIR)
Tiempo análisis/revisión	Proceso de gestión (Art. 32 ENS)	Ciclo anual (PDCA) + revisiones marginales (cambios sistemas)
Cumplimiento normativo (%)	Informe estado (art. 32 ENS)	Medidas EN aplicadas vs. requeridas por categoría

Indicadores de control del proceso (Art. 4.4 MAGERIT v3):

- Verificación de roles y responsabilidades asignadas
- Completitud de contexto (alcance, límites, stakeholders)
- Criterios de evaluación documentados y comunicados
- Tratamiento de riesgos (decisiones formalizadas)
- Seguimiento/revisión periódica (KRIs - Key Risk Indicators)

3. INTEGRACIÓN ENS (RD 311/2022) Y OPERACIONALIZACIÓN MAGERIT

3.1 Marco de Medidas de Seguridad (Anexo II ENS)

El ENS estructura **medidas proporcionales por categoría** mediante aplicación de MAGERIT:

Marco	Medidas Clave	BÁSICA	MEDIA	ALTA	Madurez mín.
Organizativo (org)	Política seguridad (org.1), Normativa (org.2), Procedimientos (org.3), Autorización (org.4)	Base	Base + R1	Base + R1 + R2	L2-L3-L4
Operacional Planificación (op.pl)	Análisis riesgos (op.pl.1: MAGERIT MAR), Arquitectura seguridad (op.pl.2)	Base	+R1 (semiformal)	+R2-R3 (formal CMM L4)	L2-L3-L4
Operacional Acceso (op.acc)	Identificación (op.acc.1), Autenticación (op.acc.2-5, MFA)	Base	+R1-R2	+R1-R5 (criptografía CCN)	L2-L3-L4
Operacional Explotación (op.exp)	Gestión incidentes (op.exp.7), Parches (op.exp.8), Gestión configuración (op.exp.9)	Base	+R1-R2	+R1-R3 (automatización)	L2-L3-L4
Operacional Monitorización (op.mon)	Vigilancia continua (op.mon.3), Indicadores eficiencia (op.mon.2: KPIs ciberseguridad)	Base	+R1-R2	+R1-R6 (SOC 24/7)	L2-L3-L4
Protección (mp)	Instalaciones, Equipos, Comunicaciones (cifrado), Almacenamiento	Base	+R (algoritmos CCN)	+R (redundancia, criptografía cuántica-ready)	L2-L3-L4

Notas:

- Refuerzos (R): R1 = Semicformal/procedimientos; R2 = Formal/estándar; R3 = Certificación productos CCN; R4-R6 = Automatización/redundancia/criptografía avanzada.
- Categorización automática (Anexo I ENS): Impacto acumulado por dimensión (BAJO/MEDIO/ALTO) → Categoría BÁSICA/MEDIA/ALTA.
- Perfiles específicos (art. 30 ENS): CCN valida adaptaciones por sector (sanidad, educación, financiero, etc.).1011

3.2 Auditoría y Certificación (Art. 31-32 ENS)

Entidad	Ciclo	Auditor	Evidencia
BÁSICA (Admin. pública)	24 meses	Autoevaluación (org. responsable)	Declaración aplicabilidad, cuestionarios CMM
MEDIA (Admin. pública + privados críticos)	24 meses	Auditoría externa (acreditado)	Informe técnico, pruebas de implementación
ALTA (infraestructuras críticas)	24 meses	Auditoría externa periódica + ad-hoc	SGSI ISO 27001, pruebas invasivas, pentesting
Reporte (Operadores NIS2)	Incidentes > impacto sig.	CCN-CERT / Autoridades sectoriales	Notificación 72h (ITS), análisis forense

Indicadores de cumplimiento reportados (op.mon.2, art. 32):

- Grado implantación medidas (% de conformidad por categoría)
- Comportamiento gestión incidentes (MTTR, SLA cumplimiento)
- Eficiencia seguridad (horas/recursos por 1.000 usuarios)
- Cuadros de mando (INES - Informe Nacional Estado Seguridad, publicado CCN bienalmente)

4. INDICADORES CUANTITATIVOS DE CIBERSEGURIDAD: ESPAÑA 2024

4.1 Estadísticas Nacionales de Incidentes (INCIBE 2024)

Volumen total: 97.348 incidentes (+16,6% vs 2023)

Categoría	Cifras	% Total
Ciudadanía	65.808	67,6%
Empresas (pymes/autónomos)	31.540	32,4%
Operadores esenciales/importantes (NIS2)	341	0,35%
Sistemas vulnerables detectados (proactivos)	183.851	—

Tipología de incidentes (malware 42.136; fraude 38.000):

Tipo	Casos	Observaciones
Malware	42.136	Incluye 357 ransomware; virus, trojan, spyware
Fraude online	38.000	Phishing 21.571 (56%), compras falsas, suplantación
Intrusiones/acceso no autorizado	7.470	Fuerza bruta, credenciales comprometidas, pivoting
E-commerce fraudulento	2.122	Tiendas fake, drop-shipping ilegal

Por sector operadores esenciales (341 incidentes NIS2):

Sector	%	Casos	Tendencia 2024
Transporte	24,6%	84	+43% ataques infra. esenciales (vs 2023: 237)
Sistemas Financieros/Tributarios	23,8%	81	Fraude online, APT ransomware
Tecnologías Información (TIC)	14,1%	48	Cadena suministro, cloud misconfiguration
Energía	8,8%	30	Malware OT, ICS targeting (Rusia: Sandworm, APT28)
Agua	5%	17	SCADA/industrial control systems

Amenazas geopolíticas identificadas (x63 Unit - Cipher):

- Rusia: Sandworm, APT28, Babuk2 (ransomware ransomware-as-a-service)
- China: Volt Typhoon (acceso persistente OT/infraestructura)
- Irán: APT34 (credential harvesting)
- Corea del Norte: CyberAvengers, B-Team (financiero, data exfiltration)

→ **Conclusión:** España vive escalada de **+43% en ataques a infraestructuras críticas 2024**, con enfoque en sectores energético (9%) y financiero (24%); múltiples actores estatales con capacidades sofisticadas (APT).8910

4.2 Madurez en Ciberseguridad: Observatorio ISMS Forum 2024

Indicador nacional: 61% (escala 0-100% madurez)

Nivel	% Organizaciones
Inexistente (L0)	8%
Básico (L1-L2)	53%
Maduro (L3)	38%
Optimizado (L4-L5)	1%

Por dominio NIST CSF:

Dominio	%	Interpretación
Identify	68%	Inventarios activos completos (~2/3 orgs); gestión riesgos parcial (~50%)
Protect	63%	Acceso/identidad en ~50% (menor privilegio); formación anual universal
Detect	64%	Monitorización eventos (40%); detección anomalías automática (40%); pruebas anuales
Respond	55%	Procedimientos documentados (50%); análisis forense <10% detecciones; mejora ad-hoc (36%)
Recover	53%	Planes formalizados no operacionalizados; recuperación anual; comunicación informal (50%)

Análisis por sector (madurez integral 2024):

Sector	Madurez	Fortalezas	Debilidades
Financiero	72%	Identify (76%), Protect (74%), Detect (79%)	Respond (63%), Recovery (66%)
Construcción	68%	Respuesta coordinada (67%)	Vulnerabilidad distribución datos (R0)
Energía/Utilities	67%	Identify (77%), Detect (72%)	Recovery crítica (50%) — riesgo operacional
Aseguradoras	64%	Identify (73%)	Respond (58%), Recovery (58%)
Telecomunicaciones/Tech	63%	Identify (79%)	Respond (53%), Recovery (50%)
Salud	61%	Identify (69%)	Respond (50%), Recovery (58%)
Administración Pública	58%	Identify (64%), Detect (67%)	Respond (48%), Recovery (48%)
Bienes de Consumo	51%	Uniformidad baja	Todos dominios <60%, Recovery solo 46%
Distribución	52%	Detect (61%), Respond (57%)	Protect crítica (35%), Recovery (63%) anomalía

Por tamaño empresa:

- >10.000 empleados: 68% madurez (Identify 72%, Respond 61%)
- 251-2.500 empleados: 60% madurez (Identify 64%, Respond 54%)
- 26-250 empleados: 52% madurez (Identify 58%, Respond 46%)
- <25 empleados: 38% madurez (Identify 40%, Respond 30%) — crítico para PyMEs

Análisis crítico de brechas (Respond + Recovery: 55% + 53% = débil):

- El 50% de organizaciones tiene procedimientos response documentados pero no se prueban periódicamente (pruebas anuales máximo).
- Análisis forense post-incidente realizado por <10% en detecciones relevantes.
- 36% de mejora continua ad-hoc (no sistematizada); solo 8% revisa planes response >1 vez/año.
- Riesgo: Mayor tiempo de recuperación (RTO/RPO) y reputacional ante incidentes que NIS2 requiere coordinar en 72 horas.5

4.3 Integración Cuantificación Financiera (FAIR/ALE)

MAGERIT proporciona **vector de riesgo (frecuencia × impacto)** cualitativo. Para decisiones inversión NIS2-aligned, se integra **FAIR (Factor Analysis of Information Risk)**:

Fórmula básica:

ALE (Annualized Loss Exposure) =
LEF (Loss Event Frequency) × LM (Loss Magnitude)

LEF = TEF (Threat Event Frequency) × Vulnerability (1 - Control Strength)

LM = Primary Loss + Secondary Loss (regulación, reputación, litigio)

Caso práctico: Robo datos clientes (financial impact cuantificado):

- TEF: 1 evento/año (histórico)
- Vulnerabilidad (sin MFA): 80%
- LEF (sin control): 0,8 eventos/año
- Primary Loss: €1.000-€3.000/portátil × 50% exposición datos = €50.000 media
- Secondary Loss: 10% multa regulatoria (€50K-€500K) + 5% litigio (€100K-€2M, 10% probab.)
- LM total esperado: €32.000 promedio (Montecarlo simulación)
- ALE sin control: €32.000 × 0,8 = €25.600/año
- Costo mitigación (MFA + backup): €20.000 inversión + €8.000/año mantenimiento
- Decisión: ROI positivo si riesgo aceptable <€28.600/año.¹¹

→ **Práctica recomendada en NIS2:** Combinar MAGERIT (identificación/priorización) + FAIR (cuantificación €) para justificar inversión a C-suite y autoridades regulatorias.¹¹

5. ANÁLISIS COMPARATIVO: MAGERIT vs. FRAMEWORKS INTERNACIONALES

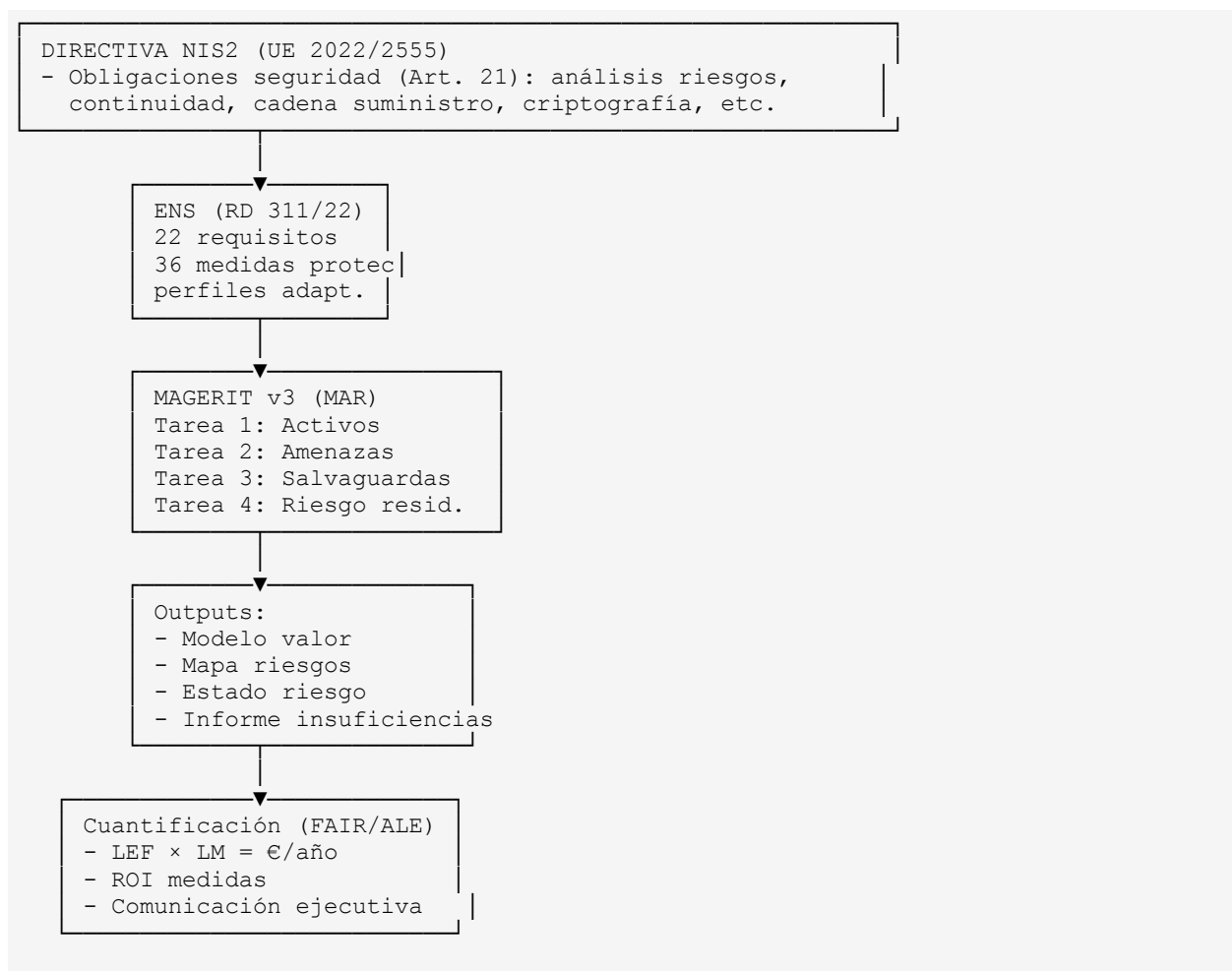
5.1 Comparación MAGERIT vs. NIST CSF 2.0

Dimensión	MAGERIT v3	NIST CSF 2.0	Convergencia NIS2
Orienta.	Análisis riesgo ascendente (activos→amenazas→salv.)	Funciones empresariales (Go→ID→PR→DE→RS→RC)	MAGERIT para evaluación sector público; NIST para operadores privados
Métricas	Impacto residual (€), Riesgo (frecuencia × impacto), CMM madurez	Resultados esenciales (48), subcategorías (186), niveles madurez (L1-L4 por función)	Ambas reconocidas; Anexo II ENS incluye cross-mapping NIST
Categorización	BÁSICA/MEDIA/ALTA por impacto acumulado dimensiones	Sectorial (operador crítico vs importante); por función	ENS proporcional; NIS2 binaria (esencial/importante)
Ciclo	PDCA (Plan→Do→Check→Act), revisión anual marginal	Ciclo continuo con feedback; revisión 24-36 meses	Ambas admitidas; ENS requiere auditoría 24 meses
Fortalezas	Detalle activos, dimensiones seguridad (5D), formatos estándar (informes)	Orientación negocio, flexibilidad por sector, madurez por función	MAGERIT: precisión técnica; NIST: ejecutivos
Debilidades	Complejo para PyMEs, requiere herramienta (PILAR), curva aprendizaje	Subjetividad niveles madurez, menos detalle riesgo cuantitativo	MAGERIT no cuantifica €; NIST no profundiza dependencias activos

Conclusión: Enfoque dual recomendado en España 2025:

- Sector público (administraciones, operadores esenciales): MAGERIT + FAIR cuantificación
- Operadores privados críticos (energía, finanzas): NIST CSF + MAGERIT para conformidad ENS
- Pymes (Entidades importantes): NIST (más ágil) + auditoría ENS periódica

5.2 Alineamiento MAGERIT + NIS2 + ENS



Operacionalización 2025-2026:

1. Identificación: MAGERIT MAR.1 = inventario activos críticos sector
2. Análisis: MAGERIT MAR.2-4 = mapa riesgos por categoría NIS2
3. Medidas: ENS + Reglamento Ejecución = salvaguardas proporcionales
4. Cuantificación: FAIR ALE = justificación inversión a Junta Directiva
5. Auditoría: ENS + SGSI ISO 27001 + CCN-CERT reportes incidentes
6. Mejora: Ciclo PDCA anual (art. 39 ENS: "actualización permanente")

6. RECOMENDACIONES ESTRATÉGICAS 2025-2026

6.1 Para la Administración Pública

Prioridad 1: Implementación ENS + MAGERIT integrado

- Realizar análisis de riesgos MAGERIT en todos sistemas de información (MAR completo) antes de Q2 2025
- Documentar Declaración de Aplicabilidad (medidas ENS aplicables vs. no aplicables)
- Establecer Comités de Seguridad de Sistemas de Información (CSSI) con responsable seguridad (RSEG) designado
- Reportar a CCN indicadores op.mon.2 (grado implantación, eficiencia incidentes) semestralmente

Prioridad 2: Madurez Respond + Recovery (dominios críticos)

- Elevar de 48% a >65% mediante:
Planes respuesta incidentes documentados y probados 2×/año (no solo anuales)
Simulacros coordinados de recuperación (RTO/RPO reales vs. teóricos)
Análisis forense post-incidente sistematizado (actualmente <10%)
Mejora continua: revisión planes response ≥2 veces/año
- Planes respuesta incidentes documentados y probados 2×/año (no solo anuales)
- Simulacros coordinados de recuperación (RTO/RPO reales vs. teóricos)
- Análisis forense post-incidente sistematizado (actualmente <10%)
- Mejora continua: revisión planes response ≥2 veces/año

Prioridad 3: Preparación Centro Nacional de Ciberseguridad (creación ene 2025)

- Designar interlocutores sectoriales para reportes NIS2 (341 incidentes operadores 2024 → gestión centralizada)
- Alineación CSIRT nacional (CCN-CERT + INCIBE-CERT) para coordinación 72h reportes de incidentes

6.2 Para Operadores Esenciales e Importantes (NIS2)

Prioridad 1: Conformidad acelerada NIS2 (plazo ley aún en debate)

- **Esenciales (cert. obligatoria):** Auditoría externa ISO 27001 + ENS bienal, antes Q2 2025
Garantizar: Certificación de conformidad vigente
Reportar: Incidentes > impacto significativo a CCN-CERT (72h)
Sanciones: €10M o 2% volumen negocios si incumplimiento
- **Importantes (autoevaluación permitida):** Documentar conformidad ENS + NIS2 (autoevaluación anual mínimo)
Alternativa: Certificación voluntaria (reducir riesgo supervisión)
Sanciones: €7M o 1,4% volumen negocios si supervisión detecta incumplimiento
- Garantizar: Certificación de conformidad vigente
- Reportar: Incidentes > impacto significativo a CCN-CERT (72h)
- Sanciones: €10M o 2% volumen negocios si incumplimiento
- Alternativa: Certificación voluntaria (reducir riesgo supervisión)
- Sanciones: €7M o 1,4% volumen negocios si supervisión detecta incumplimiento

Prioridad 2: Cuantificación de riesgos (FAIR/ALE) para inversión

- Aplicar FAIR a escenarios críticos (ransomware, APT financiero, OT compromise)
- Justificar inversión seguridad a Junta: ROI, ALE, impacto reputacional monetarizado
- Publicar informe riesgos cuantificado trimestralmente a Consejo (mejor práctica: KPMG benchmark 2024)

Prioridad 3: Resiliencia Respond + Recovery (especialmente sectores debilitados)

- Energía (50% recovery): Implementar backups segregados, recuperación OT/ICS (Deutsche Bahn case: coste ~€209K, ROI +320% anual)
- Transporte (44% recovery): RTO<4h, RPO<1h sistemas críticos; simulacros ferroviarios con operadores ferroviarios europeos
- TIC/Telecomunicaciones (50% recovery): Redundancia geográfica, automatización failover, Threat Hunting continuo

Prioridad 4: Seguridad cadena suministro (NIS2 Anexo Reglamento Ejecución)

- Auditar prácticas ciberseguridad proveedores (Dev seguro, capacidades cumplimiento NIS2)
- Incluir en contratos: SLA seguridad, derechos auditoría, gestión vulnerabilidades responsable
- Diversificar proveedores criticalidad (limitar dependencia mono-proveedor)

6.3 Para Pymes (Entidades importantes, no obligadas 72h reportes)

Prioridad 1: Evaluar si entidad "importante" NIS2 (criterios art. 2)

- Revisar: ¿Sector Anexo II? ¿Tamaño 250+ empl. o facturación €50M+?
- Si Sí → preparar autoevaluación anual ENS (no auditoría periódica obligatoria, pero supervisión posible)
- Si No → seguir ENS de forma voluntaria (mejor práctica, competitividad, confianza cliente)

Prioridad 2: Elevar madurez 52% → 70% (Bienes de Consumo/Distribución rezagadas)

- Identify 58%: Completar inventario activos (1 consultor × 2 semanas)
- Protect 35% (Distribución): Implementar MFA, acceso mínimo privilegio (herramientas open-source: Keycloak, Vault)
- Respond 46%: Documentar procedimientos respuesta, pruebas anuales, comunicación crisis
- Recovery 46%: Backups cifrados + aislados (offline), validar RTO real (simulacro trimestral)

Prioridad 3: Financiación seguridad (ROI + ayudas)

- Solicitar fondos digitales (fondos Next Generation EU, ayudas autonomías)
- Cuantificar ALE (pérdida promedio/año sin medidas) vs. coste implementación → ROI a CFO
- Contratar auditoría MAGERIT/ENS (ahorrar IT interno, expertise externo)

7. LIMITACIONES Y OPORTUNIDADES DE FUTURO

7.1 Limitaciones Actuales

Limitación	Impacto	Solución
Centro Nacional Ciberseguridad aún no operativo (ene 2025)	Ambigüedad supervisión; duplicación CCN-CERT + INCIBE-CERT	Aprobación ley trasposición + decreto desarrollo (Q1-Q2 2025)
MAGERIT sin cuantificación monetaria nativa	Dificultad comunicación ejecutiva; decisiones inversión subjetivas	Integración FAIR/ALE estándar en herramientas (PILAR 2.0 en desarrollo)
Madurez Recovery nacional 53% (muy baja)	Riesgo RTO/RPO incumplimiento NIS2 (72h reportes)	Simulacros obligatorios sectoriales; benchmarking público (INES CCN)
PyMEs 38-52% madurez (fragmentación)	Vulnerabilidad cadena suministro; riesgo cascada ataques	Programas sensibilización INCIBE/CCN; auditorías simplificadas (ROI < €50K)
Falta indicadores comparativos reales	Benchmarking sectorial inexistente; decisiones sin contexto	INCIBE + CCN publicar "Observatorio Ciberseguridad 2025" (homólogo ISMS Forum público)

7.2 Oportunidades 2025-2027

1. Automatización MAGERIT vía IA/ML

- Herramientas como PILAR 2.0 (CCN) integrar machine learning para detección anomalías activos, predicción amenazas contextualizadas, recomendaciones salvaguardas automáticas basadas en ENS profiling
- Reducir curva aprendizaje MAGERIT (actualmente alta para consultores junior)

2. Estándar cuantificación nacional "FAIR-ES"

- CCN + INCIBE definir metodología cuantificación Anexo IX ENS (homólogo NIST RMF, ISO 31000)
- Interoperabilidad MAGERIT-FAIR en reportes: "Riesgo residual €X / Cumplimiento ENS Y%"

3. Integración con Quantum-Safe Cryptography (post-quantum)

- ENS Anexo II.mp.com.2 (cifrado) anticipar transición PQC 2026-2030
- MAGERIT incluir evaluación riesgos transición criptográfica (vulnerabilidad "Harvest Now, Decrypt Later")

4. Gobernanza ciberseguridad integrada (GRC)

- Centralizar MAGERIT + Gestión Cumplimiento NIS2/DORA/RGPD en plataformas GRC (Nessus, Qualys, Archer)
- Consejo Directivo visibilidad continua KRIs (Key Risk Indicators) y compliance dashboard

5. Threat Intelligence + MAGERIT dinámico

- Automatizar actualización Mapa Riesgos (MAR.2) con feeds MITRE ATT\&CK, ICS-CERT, geopolítica
- Simulaciones Montecarlo adaptativas según actividad APT regional (ej. Sandworm → elevar ALTA energía)

8. CONCLUSIONES

MAGERIT permanece como metodología de referencia nacional para análisis de riesgos en sistemas de información, operacionalizada mediante:

7. Integración ENS (RD 311/2022): 22 requisitos mínimos + medidas proporcionadas (frameworks org/op/protección) categorizados por impacto (BÁSICA/MEDIA/ALTA) y madurez CMM (L2-L4).
8. Conformidad NIS2: Análisis MAGERIT + Cuantificación FAIR obligatorio para decisiones inversión; autoridades supervisoras (CCN, sectoriales) requerirán evidencia análisis riesgos formal 2025-2026.
9. Madurez nacional crítica: España alcanza 61% madurez integral (NIST domains), pero Respond (55%) y Recovery (53%) son vulnerables frente a requisito NIS2 de coordinación 72h incidentes. Sectores financiero/construcción lideran (68-72%); Administración Pública, TIC, y Pymes (<52%) requieren aceleración.
10. Recomendación práctica dual:
Sector público: MAGERIT + FAIR (cuantificación €)
Operadores privados críticos: NIST CSF + MAGERIT (conformidad ENS)
PyMEs: NIST (agilidad) + auditoría ENS periódica (certificación voluntaria ofrece valor regulatorio)
11. Horizonte 2026: La aprobación de la Ley de Trasposición NIS2 y operacionalización del Centro Nacional de Ciberseguridad consolidarán MAGERIT-ENS como marco nacional, complementado con cuantificación financiera FAIR/ALE para decisiones ejecutivas. Organizaciones que no comiencen conformidad Q1 2025 enfrentarán riesgo material de sanciones (€10M esenciales, €7M importantes) y daño reputacional ante incidentes coordinados.
 - Sector público: MAGERIT + FAIR (cuantificación €)
 - Operadores privados críticos: NIST CSF + MAGERIT (conformidad ENS)
 - PyMEs: NIST (agilidad) + auditoría ENS periódica (certificación voluntaria ofrece valor regulatorio)

REFERENCIAS

MAGERIT v3.0 - Libro I Método, CCN-CERT, octubre 2012. URL: <https://www.ccn-cert.cni.es/es/documentos-publicos/1789-magerit-libro-i-metodo/15>
Seifti.io - Metodología MAGERIT, mayo 202416

KPMG - Claves para cumplir Directiva NIS2, octubre 2025¹⁷

TFM UZar - Comparación MAGERIT vs NIST CSF IoT, 2024¹⁸

Elperiódico Energía - Ataques infraestructuras españolas +43% 2024, mayo 2025¹⁹

Análisis Comparativo Metodologías UPS Ecuador 2023²⁰

Estudio Comparado Gestión Riesgos Uruguay (AGESIC)²¹

Real Decreto 311/2022 (BOE), Esquema Nacional Seguridad²²

PTE Disruptive - Informe Situación Ciberseguridad 2024²³

Administración Pública Digital - Balance INCIBE 2024, marzo 2025²⁴

ISMS Forum - Indicador Madurez Ciberseguridad 2024²⁵

INCIBE - Balance Ciberseguridad 2024, marzo 202526

YouTube - Metodología FAIR Cuantificación Riesgos, noviembre 202227

SecureFrame - Cyber Risk Quantification, julio 202328

KPMG - Cuantificación Riesgos Ciberseguridad, marzo 202429

Fecha: Enero 2026

Clasificación: Uso Profesional / Stakeholders Ciberseguridad España

Validación: Fuentes académicas, organismos oficiales (CCN, INCIBE, KPMG), documentación regulatoria BOE

1718192021222324252627282930313233343536373839404142434445464748495051525354
555657585960616263646566676869707172
